

Pinecastle - NIST CSF 2.0 Gap Assessment

Assessed Outcomes Implemented	18	1	CSF Function	Outcomes	High Priority	Main Theme	Near-Term Focus
			GOVERN		5	4 Accountability, risk appetite, vendor oversight	Quarterly risk review
Partially Implemented	16		IDENTIFY		3	2 Assets, vulnerabilities, improvement tracking	Inventory and SLA governance
Not Implemented	1		PROTECT		4	2 Access, training, configuration, data protection	Privileged MFA and baselines
High Priority Gaps	12		DETECT		2	1 Logging, alert ownership, triage	Log and alert ownership
Assessment Date	2026-08-19		RESPOND		2	2 IR plan, communications , tabletop	Tabletop exercise
			RECOVER		2	1 Backup restoration, DR, customer communications	Restore testing

Highest Priority Gaps	Function	Status	Risk	Recommendation	Owner	Priority	Roadmap
GV.OC-01	GOVERN	Partially Implemented	Medium	Create annual security strategy review tied to business goals	CISO	High	0-30 days
GV.RM-01	GOVERN	Partially Implemented	High	Define risk appetite and escalation thresholds	CISO / CFO	High	31-90 days
GV.RR-02	GOVERN	Partially Implemented	Medium	Create control-owner matrix	GRC Lead	High	31-90 days
GV.SC-04	GOVERN	Partially Implemented	High	Implement vendor tiering and annual critical vendor assessment	Procurement / GRC	High	31-90 days
ID.AM-01	IDENTIFY	Partially Implemented	High	Assign owners and reconcile assets monthly	IT Operations	High	31-90 days

CSF ID	Function	Outcome	Current Status	Current Evidence	Target State	Gap	Business Risk	Recommendation	Owner	Priority	Roadmap Phase	Framework References
GV.OC-01	GOVERN	Organizational context and mission understood	Partially Implemented	Company profile exists; customer obligations known	Documented business context, security objectives, and customer commitments reviewed annually	Security objectives not formally reviewed with leadership	Medium	Create annual security strategy review tied to business goals	CISO	High	0-30 days	NIST SP 1308; ISO 27001 Clause 4
GV.RM-01	GOVERN	Risk management objectives established	Partially Implemented	Risk register created in Project 1	Approved cyber risk appetite/tolerance and escalation criteria	Risk appetite not formally approved	High	Define risk appetite and escalation thresholds	CISO / CFO	High	31-90 days	NIST IR 8286 Rev. 1
GV.RR-02	GOVERN	Cybersecurity roles and responsibilities assigned	Partially Implemented	Owners listed in risk register	Named control owners and backup owners for key domains	Ownership not complete for every key control	Medium	Create control-owner matrix	GRC Lead	High	31-90 days	ISO 27001 Clause 5
GV.PO-01	GOVERN	Cybersecurity policies established	Partially Implemented	Policy set exists	Policies approved, reviewed annually, and mapped to controls	Policy review cadence inconsistent	Medium	Approve annual policy review calendar	GRC Lead	Medium	0-30 days	ISO 27001 Clause 5; SOC 2 CC1
GV.SC-04	GOVERN	Supplier risk managed	Partially Implemented	Vendor list exists	Risk-tiered vendor program with annual critical vendor reviews	Critical vendor tiering incomplete	High	Implement vendor tiering and annual critical vendor assessment	Procurement / GRC	High	31-90 days	NIST SP 800-161 Rev. 1 Update 1; CIS 15
ID.AM-01	IDENTIFY	Assets inventoried	Partially Implemented	Cloud and SaaS systems known	Authoritative asset inventory with owner and criticality	Inventory not consistently owned or reconciled	High	Assign owners and reconcile assets monthly	IT Operations	High	31-90 days	CIS 1, CIS 2
ID.RA-01	IDENTIFY	Vulnerabilities identified and documented	Partially Implemented	Scanning occurs	Vulnerability findings tracked to SLA with exception workflow	SLA evidence inconsistent	High	Adopt remediation SLA and exception process	Security Engineer	High	31-90 days	NIST 800-53 RA-5; CIS 7
ID.IM-02	IDENTIFY	Improvements identified from assessments	Partially Implemented	Project risk assessment and CSF assessment exist	Assessment findings tracked through closure	No standing governance cadence for findings	Medium	Create monthly remediation review	GRC Lead	Medium	31-90 days	NIST IR 8286C Rev. 1
PR.AA-01	PROTECT	Identities and credentials managed	Partially Implemented	SSO and MFA enabled	Centralized identity lifecycle with enforced MFA and reviewed exceptions	Privileged MFA exceptions and reviews need improvement	High	Enforce phishing-resistant MFA for admins and quarterly access reviews	VP of IT	High	0-30 days	NIST 800-53 IA-2; CIS 6
PR.AT-01	PROTECT	Personnel receive security awareness	Partially Implemented	Annual training exists	Training completion evidenced for employees and contractors	Contractor training evidence incomplete	Medium	Expand training tracker to contractors	People Operations	Medium	31-90 days	NIST 800-53 AT-2; CIS 14
PR.DS-01	PROTECT	Data-at-rest protected	Implemented	Cloud encryption standards enabled	Encryption enforced and reviewed for data stores	No material gap identified for baseline encryption	Low	Continue periodic configuration review	Cloud Engineering	Low	6-12 months	ISO 27002; ISO 27017:2026
PR.PS-01	PROTECT	Configuration management practiced	Partially Implemented	IaC and change reviews exist	Configuration baselines monitored with security exceptions tracked	Cloud configuration monitoring incomplete	High	Implement configuration monitoring and monthly owner review	Cloud Engineering	High	31-90 days	NIST 800-53 CM-2; CIS 4
DE.CM-01	DETECT	Networks and services monitored	Partially Implemented	Cloud and SaaS logs available	Critical logs mapped, retained, alerted, and owned	Alert ownership and coverage not fully mapped	High	Map critical log sources and alert owners	Security Operations	High	31-90 days	NIST 800-53 SI-4; CIS 8
DE.AE-02	DETECT	Potentially adverse events analyzed	Partially Implemented	Some alerts reviewed	Alert triage procedure with documented escalation	Triage documentation inconsistent	Medium	Document alert triage and escalation criteria	Security Operations	Medium	3-6 months	NIST SP 800-61 Rev. 3
RS.MA-01	RESPOND	Incident response executed	Partially Implemented	IR plan exists	Plan tested through tabletop with lessons learned	No recent tabletop exercise	High	Conduct tabletop exercise and track corrective actions	CISO	High	3-6 months	NIST SP 800-61 Rev. 3; CIS 17
RS.CO-03	RESPOND	Information shared with stakeholders	Partially Implemented	Escalation contacts exist	Legal, customer, executive communications playbook tested	Communication playbook not exercised	High	Add stakeholder communications to tabletop	Legal / CISO	High	3-6 months	NIST SP 800-61 Rev. 3
RC.RP-01	RECOVER	Recovery plan executed	Partially Implemented	Backups exist	Recovery tested against RTO/RPO	Recovery testing evidence incomplete	High	Perform backup restoration and DR test	Infrastructure	High	3-6 months	NIST 800-53 CP-10; CIS 11
RC.CO-03	RECOVER	Recovery activities communicated	Not Implemented	No formal evidence	Recovery communications plan for customers and executives	No tested recovery communications plan	Medium	Create recovery communications template and exercise it	Customer Operations / Legal	Medium	6-12 months	NIST CSF 2.0 Recover

Roadmap Phase	Action	Related CSF IDs	Owner	Priority	Expected Evidence	Success Measure	Dependency
0-30 days	Approve security governance owners and policy review calendar	GV.OC-01, GV.PO-01	CISO / GRC	High	Approved calendar, owner matrix	Owners assigned for key controls	None. This row starts the program.
0-30 days	Remove unmanaged privileged MFA exceptions	PR.AA-01	VP of IT	High	MFA policy export, exception log	100% admin MFA enforcement or approved exception	Contractor MFA exceptions surfaced in control testing (CF-001)
31-90 days	Implement vendor risk tiering and critical vendor reviews	GV.SC-04	Procurement / GRC	High	Vendor inventory, tiering matrix, review evidence	Critical vendors identified and review cadence set	Vendor inherent-risk intake from the risk register (R-014)
31-90 days	Adopt vulnerability remediation SLA and reporting	ID.RA-01	Security Engineer	High	SLA policy, vulnerability aging report	Overdue critical vulnerabilities reported monthly	An approved exception path for overdue criticals (SOCF-004)
31-90 days	Map critical log sources and alert owners	DE.CM-01	Security Operations	High	Log source inventory, alert routing matrix	Critical alerts have named owner	Alert owners named in the row 2 owner matrix
3-6 months	Conduct incident-response tabletop	RS.MA-01, RS.CO-03	CISO / Legal	High	Exercise agenda, participant list, lessons learned	Corrective actions opened and tracked	Legal and Customer Operations availability for a half-day exercise
3-6 months	Perform backup restoration and DR test	RC.RP-01	Infrastructure	High	Restore test record, RTO/RPO results	Recovery objective met or gap documented	Updated DR runbook (R-017)
6-12 months	Build SOC 2 readiness evidence inventory	GV.RR-02, ID.IM-02	GRC Lead	Medium	Evidence tracker, owner assignments	Evidence owners and review cadence established	Owners from row 2; tabletop and restore results from rows 7 and 8

Reference	URL	Use in Workbook
NIST CSF 2.0	https://www.nist.gov/cyberframework	Primary program framework and functions
NIST SP 800-30 Rev. 1	https://csrc.nist.gov/pubs/sp/800/30/r1/final	Risk-assessment methodology
NIST IR 8286 Rev. 1	https://csrc.nist.gov/pubs/ir/8286/r1/final	Cybersecurity risk integration with ERM
NIST IR 8286A Rev. 1	https://csrc.nist.gov/pubs/ir/8286/a/r1/final	Risk identification and estimation for ERM
NIST IR 8286C Rev. 1	https://csrc.nist.gov/pubs/ir/8286/c/r1/final	Risk staging and governance oversight
NIST SP 1308	https://csrc.nist.gov/pubs/sp/1308/final	CSF 2.0, ERM, and workforce management
NIST SP 800-53 Rev. 5 Release 5.2.0	https://csrc.nist.gov/News/2025/nist-releases-revision-to-sp-800-53-controls	Control catalog reference
NIST SP 800-53A Rev. 5	https://csrc.nist.gov/pubs/sp/800/53/a/r5/final	Control assessment reference
NIST SP 800-161 Rev. 1 Update 1	https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final	Supply-chain risk reference
CIS Controls v8.1	https://www.cisecurity.org/controls/v8-1	Prioritized safeguards
ISO/IEC 27001:2022/Amd 1:2024	https://www.iso.org/standard/88435.html	ISMS requirements
ISO/IEC 27002:2022	https://www.iso.org/standard/75652.html	Security control guidance
AICPA TSC revised points of focus 2022	https://www.aicpa-cima.com/resources/download/2017-trust-services-criteria-with-revised-points-of-focus-2022	SOC 2 criteria reference
NIST SP 800-61 Rev. 3	https://csrc.nist.gov/pubs/sp/800/61/r3/final	Incident response
NIST SP 800-171 Rev. 3	https://csrc.nist.gov/pubs/sp/800/171/r3/final	CUI reference where relevant
ISO/IEC 27017:2026	https://www.iso.org/standard/43757.html	Cloud-specific control guidance
PCI DSS v4.0.1	https://www.pcisecuritystandards.org/document_library/	Payment-card reference where relevant
Scenario dates and rating definitions	Fictional assessment assumptions; see shared company profile	../../00-company-profile/Pinecastle-Company-and-GRC-Scope.md